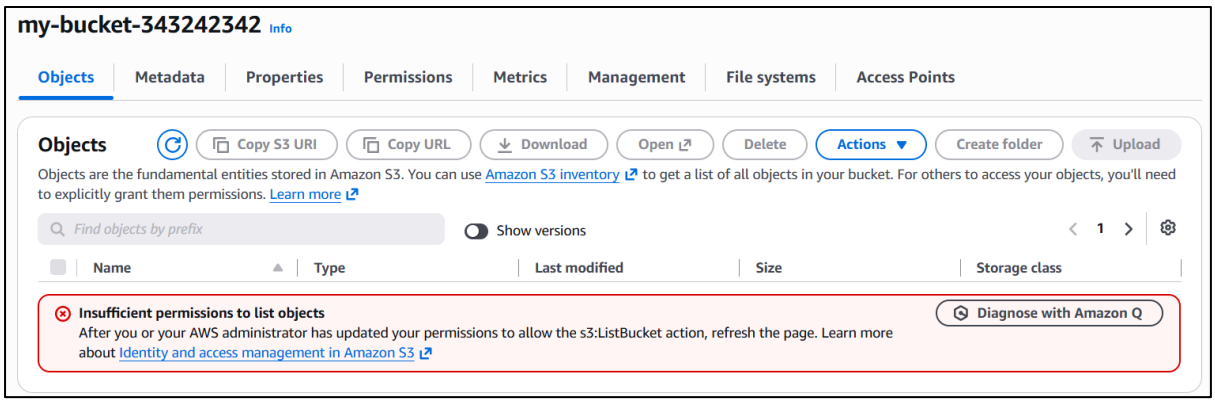
Security In The Cloud – Assignment-5

1. Create a new IAM user in your chosen cloud provider (AWS, Azure, or GCP) named 'foodieAppTester' and assign only the permissions needed to list storage buckets or containers, but not to create or delete them. Hint: Use built-in roles like 'Storage Viewer' or create a custom policy with only 'list' actions.

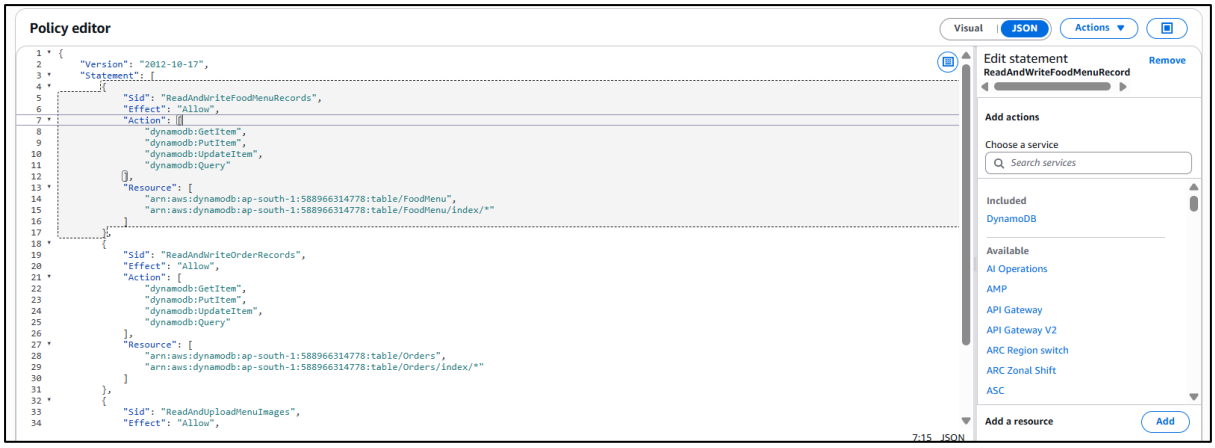


2. Audit the permissions of an existing IAM user or role in your cloud account and identify at least two permissions that are broader than necessary for a Zomato-style food delivery app backend (for example, full access to all services instead of just database and storage read/write).



3. Modify the overly broad permissions you found in the previous task by editing the policy to restrict access only to the required services and actions (for example, allow only read/write to the food menu database and order storage, deny all other actions).

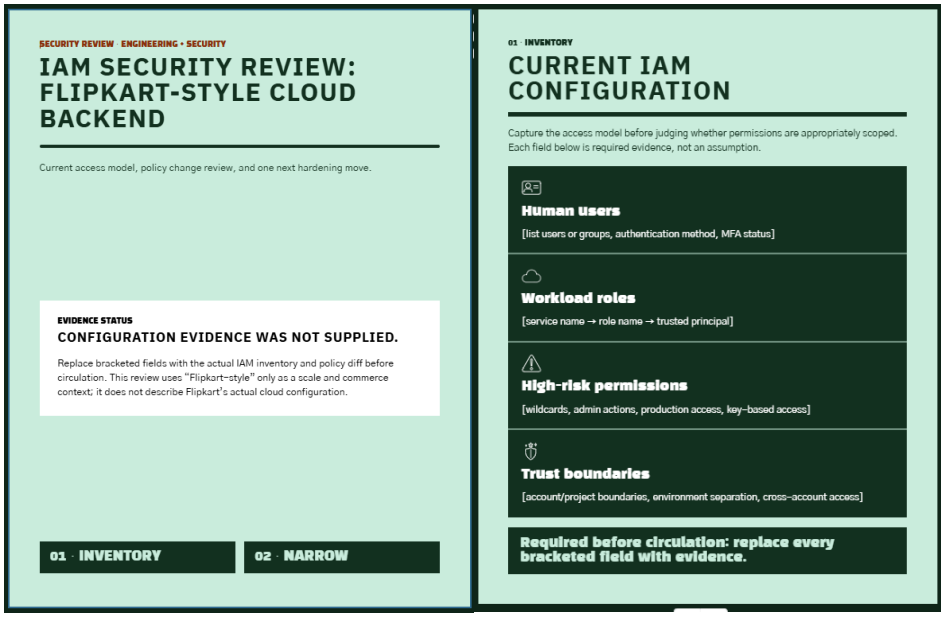
Security In The Cloud – Assignment-5



4. Use ChatGPT or Copilot to generate a least-privilege IAM policy JSON for a user who only needs to upload profile pictures to a 'user-profile-pics' storage bucket. Review the generated policy and apply it to a test user. Hint: Ask the AI tool to explain each permission in the policy so you understand what it allows.



5. Prepare a 3-minute presentation or a 1-page document showing your IAM user/role configurations, the before-and-after policy changes, and suggest one improvement to further tighten security for a Flipkart-style cloud backend.



Security In The Cloud – Assignment-5

02 · POLICY DIFF

BEFORE → AFTER POLICY CHANGES

Use this comparison as the decision record. The revised statement should show least-privilege scope, conditions, and resource limits, with validation attached.

Control area	Before	After	Evidence
Human access	[fill in]	[fill in]	[fill in]
Service role	[fill in]	[fill in]	[fill in]
Sensitive data	[fill in]	[fill in]	[fill in]

Before

[policy statement, principal, resource, and risk]

After

[revised statement with least-privilege scope, conditions, and resource limits]

Why it is safer

[removed wildcard action/resource, narrowed principal, added condition, or reduced duration]

Validation

[test result, access review, or denied-action evidence]

02 · HARDENING MOVE

RECOMMENDED NEXT MOVE: REMOVE STANDING PRIVILEGE

Make privileged access temporary, attributable, and reviewable.

1 Federate human access

Require federated, MFA-protected human access and short-lived role credentials.

2 Scope permissions

Replace broad permissions with resource-scoped actions and explicit deny conditions for production data.

3 Review use on a fixed cadence

Review role use and denied requests; remove unused users, keys, and permissions.

SUCCESS LOOKS LIKE

NO UNMANAGED LONG-LIVED HUMAN KEYS.

No unexplained production admin path, and a recorded owner for every privileged role.